

Draft - Data Processing Agreement (Taweed <-> Clinic)

Draft - Data Processing Agreement (Taweed <-> Clinic)

Status: skeleton only, structured on standard DPA form (PDPL-aligned, comparable in shape to GDPR Art. 28 DPAs since PDPL's processor obligations are similarly structured). Source: HUMAN_CONFIRMATION_NEEDED.md C1/G14. Assumes the likely-but-unconfirmed determination that Taweed is processor and the clinic is controller - if 04-controller-processor-determination.md resolves differently, the role language throughout needs to flip, not just be tweaked.

This is the agreement Taweed signs with each clinic customer, governing how Taweed handles the clinic's patients' PHI. It's separate from 01's SCC (which governs the further transfer from Taweed to Anthropic) - this DPA is what authorizes Taweed to make that further transfer at all (see §6 below).

1. Parties and roles

- Controller: the clinic (owns the patient relationship and the underlying NPHIES data).
- Processor: Taweed (processes the data solely to deliver the denial-management/appeal-drafting service under the underlying commercial contract).
- [COUNSEL TO CONFIRM this role assignment per 04 before use.]

2. Subject matter, duration, nature and purpose of processing

- Subject matter: processing of insurance claims data (NPHIES ClaimResponse/EOB records) to detect denials, explain billing-rule flags, draft appeal letters, and extract structured data from remittance documents.
- Duration: for the term of the underlying commercial agreement, plus any post-termination retention/deletion period set in §8.
- Nature of processing: automated analysis (rule-matching + AI-assisted drafting/extraction), human-clinic-reviewed output, no automated decision-making with legal/similarly-significant effect on patients (Taweed's output is always clinic-reviewed before use).
- Purpose: solely to provide the contracted service - no independent use, no resale, no cross-client training on the clinic's data.

3. Categories of data subjects and personal data

- Data subjects: patients whose claims are processed through the clinic's NPHIES submissions.
- Categories of data: [ENGINEERING + COUNSEL TO CONFIRM exact fields against the real schema - do not assume from this template] - likely claim identifiers, denial-reason codes, monetary amounts, and whatever patient-identifying fields are present in the source ClaimResponse payload. Sensitive/health data under PDPL - no lighter-touch category applies.

4. Processor obligations

- Process personal data only on the controller's (clinic's) documented instructions, including regarding cross-border transfers - unless required otherwise by KSA law, in which case Taweed must inform the clinic before processing (standard DPA clause; [COUNSEL TO CONFIRM PDPL's exact equivalent wording, this mirrors GDPR Art. 28(3)(a) which may not map exactly]).
- Ensure personnel with data access are bound by confidentiality.
- Implement appropriate technical and organizational security measures - reference Taweed's actual

security posture (data_origin synthetic/production gate, encryption in transit/at rest, access controls) [ENGINEERING TO PROVIDE a current, accurate list at signing time - do not let this section go stale relative to the real stack].

- Assist the clinic in responding to data-subject rights requests (access, correction, deletion) to the extent Taweed holds the relevant data.
- Assist the clinic in meeting its own breach-notification and SDAIA risk-assessment obligations - ties directly to 03-breach-notification-runbook.md's internal SLA.
- Not engage a sub-processor without the clinic's prior authorization (general or specific) - see §6.
- Make available all information necessary to demonstrate compliance, and allow for audits [COUNSEL TO SET reasonable audit terms - frequency, notice period, cost allocation].

5. Controller (clinic) obligations

- Ensure it has a lawful basis under PDPL for the underlying processing and for engaging Taweed.
- Provide only the data actually necessary for the contracted service (data minimization is a shared discipline, not solely Taweed's problem).
- Respond to data-subject rights requests, with Taweed's assistance per §4.

6. Sub-processing (the Anthropic transfer)

- Taweed's use of Anthropic (US-based) as an AI sub-processor for AI-2 (appeal drafting) and AI-4 (EOB extraction) is disclosed here as a general authorization, subject to:
 - The safeguards in 01-scc-controller-to-processor.md being in place and current.
 - The risk assessment in 02-sdaia-risk-assessment.md being completed before any real-PHI transfer occurs.
- Taweed notifying the clinic of any change in sub-processor (new AI vendor, e.g. the contingency plan in docs/05_open_source_switching.md) with the opportunity to object.
- [COUNSEL TO CONFIRM whether PDPL requires specific (named, per-instance) versus general sub-processor authorization - this affects whether future AI-provider changes need a DPA amendment or just a notice.]

7. Data subject rights

Taweed will, at the clinic's request, assist with access/correction/deletion requests to the extent it holds the relevant data - noting that Taweed's role is transient processing (per §2), so most of the underlying data of record likely stays with the clinic/NPHIES rather than being independently retained by Taweed. [ENGINEERING TO CONFIRM actual data-retention behavior of the product before this clause is finalized - do not assume "we don't store it" without checking.]

8. Term, termination, and data return/deletion

- On termination of the underlying commercial agreement, Taweed will delete or return all clinic personal data within [COUNSEL TO SET a concrete period, e.g. 30/60/90 days], except where KSA law requires retention.
- [ENGINEERING TO CONFIRM what's actually retained today - logs, backups, analytics - before committing to a deletion timeline the product can't actually meet.]

9. Liability

[COUNSEL TO DRAFT] - allocation of liability for a breach caused by Taweed vs. by the clinic vs. by a sub-processor (Anthropic); align with what Anthropic's own terms allow Taweed to pass through, so this DPA doesn't promise the clinic something Taweed can't actually deliver against Anthropic.

10. Governing law

Saudi Arabia / PDPL.

Open items before this can be used with a real clinic

1. Resolve 04-controller-processor-determination.md - the entire role structure above depends on it.
2. Get engineering's actual, current data-retention and field-level answers (marked throughout) - several clauses here are placeholders pending real facts about the product, not just legal drafting.
3. Finalize 01 and 02 first, or at minimum in parallel - §6 references both directly.
4. This is a template for one clinic; confirm with counsel whether a master DPA + per-clinic order form is more practical once there's more than a handful of customers, versus a fresh DPA per signature every time.